ITA14 – ETHICAL HACKING

ASSIGNMENT 1 – CO1

Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Student Name: Vempati Murale Karrtik

Register Number: 192312567

Department: INFORMATION TECHNOLOGY

Submission Date: _____

ASSIGNMENT QUESTION PAPER

Scenario – University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

Management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is to investigate requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must distinguish between what is authorized, what is legal and what is appropriate for the university. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. Define how an engagement is authorized, how scope and rules of engagement are set, how relevant laws are respected, how attacker types are modelled, how vulnerabilities are disclosed responsibly and how an isolated lab is used where hands-on testing is required.

TASK 1 – Formulate the Enquiry and Framework Blueprint

- Convert the scenario into formal engagement-governance requirements. Identify systems in scope, stakeholders, expected activities and constraints.
- Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure cooperate.
- Formulate at least four enquiry questions: who authorizes a test, what is in scope, which laws apply and how findings are disclosed.
- Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected: Requirements-to-governance blueprint, enquiry questions, design criteria and rationale.

TASK 2 – Design a Hacker Threat Model and Classification

- Classify relevant hacker types: white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.
- Map each type to motivation, typical capability and likely university targets.
- Establish clear criteria and naming so an actor can be classified consistently.
- Demonstrate two alternative classifications of one borderline actor, then choose and justify the final classification.

Evidence Expected: Threat model, classification criteria, mapping table, rejected alternatives and justified classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module

- Define ethical principles: written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.
- Design rules or checks that detect or prevent unethical actions during an engagement.
- Construct acceptable, borderline and unacceptable scenarios and show how the code responds.
- Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected: Reusable code of conduct, decision rules, scenario test cases and evidence that rules distinguish acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping

- Map the engagement to relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.
- Build a table of offences, obligations and penalties related to unauthorized access and data protection.
- Connect each legal requirement to a specific control in the engagement framework.

- Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected: Legal-compliance mapping, offences-and-penalties table, linked controls and justified conclusion on applicable laws.

ASSIGNMENT QUESTION PAPER (CONTINUED)

TASK 5 – Create a Scope and Rules-of-Engagement Document

- Design a scope and rules-of-engagement (RoE) document defining in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.
- Create rules for recording and verifying written authorization behind each engagement.
- Establish clear naming and boundaries so an out-of-scope request can be detected.
- Transform the RoE into a pre-engagement checklist.

Evidence Expected: Complete RoE document, authorization-verification rules, scope boundaries and derived pre-engagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer

- Create an authorization workflow covering request, approval, written sign-off and recording of each engagement.
- Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline; compare it with full disclosure and bug-bounty approaches.
- Develop operations for logging approvals and status updates and deciding when disclosure may proceed.
- Create rules for choosing between coordinated and full disclosure for a finding.
- Demonstrate interaction with rules-of-engagement and legal-compliance components.

Evidence Expected: Authorization workflow, responsible-disclosure process, logging and decision operations, disclosure rules and evidence of integration.

TASK 7 – Design an Isolated Ethical-Hacking Lab

- Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.
- Specify components, roles, connectivity and steps used to record the lab configuration.
- Develop at least two operations, such as verifying connectivity and recording the lab setup.
- Compare host-only and NAT lab networks and justify the chosen design.
- Explain how the lab keeps testing authorized and contained.

Evidence Expected: Isolated-lab design, component and connectivity specification, verification operations, network comparison and justified lab model.

TASK 8 – Develop a Reusable Document Library

- Create at least four reusable engagement documents, including one authorization form and one finding report.
- Use sensible default fields and explicitly design each document.
- At least one document must produce structured output that integrates with another framework component.
- Create valid, boundary and invalid test entries and document expected results.

Evidence Expected: Reusable document library, fields, structured report output, test entries and integration evidence.

ASSIGNMENT QUESTION PAPER (CONTINUED)

TASK 9 – Integrate, Test and Refine the Framework

- Integrate components from Tasks 2–8 into one coherent engagement framework.
- Construct a realistic walkthrough from request and authorization, through isolated-lab testing, to responsible disclosure.
- Design test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.
- Record problems during the walkthrough and show how the framework was refined.

Evidence Expected: Reproducible integrated framework, workflow walkthrough, systematic test cases, refinement evidence and corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation

- Construct small-programme (one department) and large-programme (whole university with external assessors) scenarios, including systems and testers.
- Experiment with at least three processes and record measures such as approval turnaround, scope coverage or number of steps.
- Create a comparison table and at least one suitable chart or structured visualization.
- Use evidence to refine governance rather than simply reporting measures.

Evidence Expected: Reproducible evaluation setup, comparison table, visualization, interpretation and at least one governance refinement.

TASK 11 – Defend the Framework Under a Changed Requirement

- Changed requirement: continuous and third-party assessments, stricter data-protection rules, shorter disclosure timeline and a framework that remains easy to govern and extend.
- Revise the framework by deciding which components are retained, modified, replaced or redesigned.
- Construct a new or modified component that addresses the changed requirement and show integration.
- Defend the final framework using evidence from the walkthrough, scalability evaluation, legal mapping and disclosure process.
- Identify at least two remaining trade-offs or limitations and propose future improvements.

Evidence Expected: Revised framework, demonstrated adaptation, evidence-based defence, explicit trade-offs and explanation of how the design satisfies changed requirements.

MARK DISTRIBUTION

Task	**Assessed Area**
Task 1	Enquiry and framework blueprint
Task 2	Hacker threat model and classification
Task 3	Ethics and code of conduct
Task 4	Legal-compliance mapping
Task 5	Scope and rules of engagement
Task 6	Authorization and disclosure
Task 7	Isolated ethical-hacking lab
Task 8	Reusable document library
Task 9	Integration, testing and refinement
Task 10	Scalability and governance evaluation
Task 11	Framework defence under changed requirement
TOTAL	

ANSWERS – TASK 1 TO TASK 11

TASK 1 – Enquiry and Framework Blueprint

The university needs a repeatable governance process for assessing the student portal, learning-management system, email service and campus network. The initial programme covers approximately 20 systems and 50 staff and must scale to the whole university and external assessors.

Requirement area	Requirement	Governance response
Authorization	Every engagement must have written approval	Signed request and approval register
Scope	Assets and exclusions must be unambiguous	Asset list, IP/domain boundaries and test window
Stakeholders	IT owner, security team, legal/privacy office, assessor	Named roles and escalation contacts
Safety	Avoid service interruption and data exposure	Non-destructive tests, isolated lab and stop conditions
Evidence	Findings must be traceable	Timestamped logs and structured reports
Disclosure	Vulnerabilities handled responsibly	Coordinated disclosure timeline and closure record



Figure 1. Governance blueprint connecting authorization, scope, compliance, lab testing and disclosure.

1.1 Enquiry questions

1. Who has authority to approve testing on each university system?
2. Which domains, IP ranges, applications, accounts and dates are included or excluded?
3. Which Indian legal and data-protection obligations apply, and are any other jurisdictions involved?
4. How will evidence be protected and who can access it?
5. Who receives a vulnerability report, and what remediation period applies?

1.2 Design and acceptance criteria

Criterion	Acceptance test
Authorization	No test begins without signed approval
Scope control	Every tested asset matches the approved inventory
Legal and privacy compliance	Data handling and access controls are documented
Safety	Stop conditions and emergency contacts are defined
Traceability	Every action and finding has an evidence reference
Disclosure	Owner acknowledgement, remediation and closure are recorded
Scalability	The same templates support departments and external assessors

The framework is accepted only when all criteria pass in a tabletop walkthrough. The university should appoint an engagement owner and maintain a central register to prevent conflicting requests.

TASK 2 – Hacker Threat Model and Classification

A threat model classifies actors by authorization, intent, capability and target. The same technical skill can be used ethically or maliciously; permission and behaviour are therefore central classification criteria.

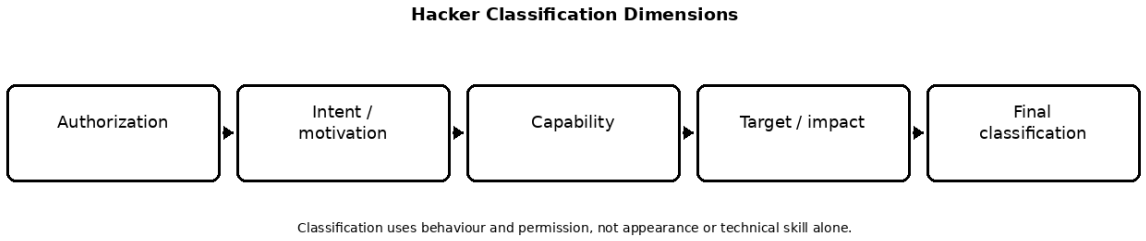


Figure 2. Classification dimensions used to evaluate an actor.

Actor type	Motivation	Typical capability	Likely university target
White-hat	Improve security with permission	Authorized assessment and reporting	Portal, LMS, network
Black-hat	Financial gain, theft or disruption	Credential theft, malware or exploitation	Student records, email, payment systems
Grey-hat	Curiosity or recognition; may lack permission	Unrequested probing or disclosure	Public portal or exposed service
Script kiddie	Experimentation, attention or disruption	Uses ready-made tools with limited understanding	Public-facing websites
Hacktivist	Political or social cause	Defacement, disruption or data exposure	University website and public services
Insider	Grievance, gain or accidental misuse	Legitimate access misused or mishandled	Internal records and shared drives
State-sponsored	Strategic intelligence or influence	Well-resourced, persistent operations	Research data and institutional accounts

2.1 Consistent classification criteria

- Authorization: written permission exists, is absent or is exceeded.
- Intent: defensive, curious, financial, disruptive, ideological or strategic.
- Capability: basic tools, moderate technical skill or advanced resources.
- Behaviour: respects limits, reports responsibly, conceals activity or causes harm.

2.2 Borderline example

An individual discovers an exposed university webpage and accesses information without permission, then privately informs the university. One interpretation is “white-hat” because the person reports the issue; another is “grey-hat” because access was not authorized. The final classification is grey-hat: good-faith reporting does not retroactively create authorization. The university should acknowledge the report, avoid encouraging further access and route it through the disclosure process.

The classification is based on observed conduct and available evidence, not assumptions about the person.

TASK 3 – Ethics and Code-of-Conduct Module

All assessors must sign a code of conduct before work begins. The code protects university users, systems, personal information and the credibility of the assessment.

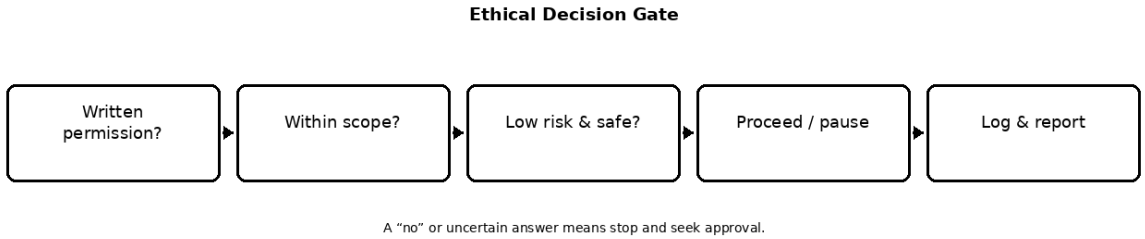


Figure 3. Ethical decision gate. Any missing or uncertain permission requires a pause.

Principle	Required behaviour	Control
Authorization	Test only with written approval	Verify signed authorization ID
Scope	Stay within listed systems and dates	Allowlist and scope checklist
Confidentiality	Protect student and staff information	Least-privilege access and encryption
Integrity	Do not alter or destroy data	Non-destructive methods and evidence logs
Avoid harm	Stop if instability or unexpected impact occurs	Stop-work trigger and escalation contact
Honesty	Report findings accurately	Evidence-backed report and peer review
Accountability	Record actions and decisions	Timestamped activity log

3.1 Scenario decisions

Scenario	Classification	Required response
Tester checks an approved lab host during the agreed window	Acceptable	Proceed and record evidence
Tester finds a related host not listed in scope	Borderline / not permitted	Stop; request written scope amendment
Tester downloads an entire student database to prove access	Unacceptable	Stop immediately; notify owner and privacy contact
Tester discovers a critical issue and reports it privately	Acceptable	Use coordinated disclosure process
Tester posts a vulnerability publicly before notifying owner	Unacceptable under programme rules	Escalate and follow incident/disclosure policy

A decision rule is: if authorization, scope or safety is unclear, stop and ask the engagement owner. This protects trust and prevents "good intentions" from being used as a substitute for permission.

TASK 4 – Legal-Compliance Mapping

The university is in India, so the Information Technology Act, 2000 is a key legal reference. The US Computer Fraud and Abuse Act (CFAA) is a useful international comparison, but it does not automatically govern a university assessment conducted wholly in India. Cross-border systems, assessors or affected services require jurisdiction-specific legal review.

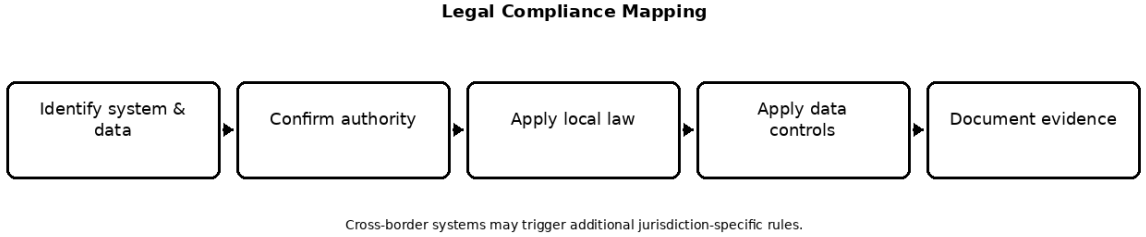


Figure 4. Legal and privacy review is a required gate before engagement approval.

Legal reference	Main subject (summary)	Framework control
IT Act, 2000 – Section 43	Unauthorized access, copying, introducing contaminants and related acts may attract civil liability when done without permission	Written authorization, scope allowlist and activity logging
IT Act, 2000 – Section 66	Certain Section 43 acts become criminal offences when done dishonestly or fraudulently	Prohibit unauthorized access and malicious activity; escalation process
IT Act, 2000 – Section 72	Breach of confidentiality and privacy by a person with powers under the Act	Confidentiality commitments and restricted evidence access
IT Act, 2000 – Section 72A	Disclosure of information in breach of lawful contract in specified circumstances	NDA, data minimization and controlled report distribution
CFAA – 18 U.S.C. § 1030	US federal law addressing unauthorized computer access and related conduct	Confirm applicable jurisdiction and obtain explicit system-owner permission
Personal-data requirements	Personal data requires lawful, purpose-limited and secure handling under applicable Indian data-protection requirements	Minimize collection, redact evidence, restrict retention and consult privacy/legal office

4.1 Offence, obligation and penalty considerations

The assignment asks for offences, obligations and penalties. Exact penalty amounts and applicability depend on the current statutory text, facts, amendments and jurisdiction. The table below deliberately summarizes the legal exposure rather than presenting potentially outdated penalty figures.

Issue	Possible legal consequence / obligation	University control
Unauthorized access or damage	Civil compensation and, where statutory criminal elements are met, criminal consequences	Written scope, authorization verification and stop-work rules
Dishonest or fraudulent computer-related acts	Criminal liability may arise under Section 66 when its requirements are met	No testing outside approved purpose or boundary
Confidentiality breach	Liability for improper disclosure of information obtained under relevant authority or contract	NDA, encrypted storage and need-to-know access
Personal data exposure	Applicable data-protection duties, security safeguards and breach-response obligations	Data minimization, redaction, retention limits and incident escalation

When personal data may be encountered, the engagement owner must consult the university legal/privacy function before testing. The assessor should avoid collecting actual records; use synthetic data in the lab and retain only the minimum proof needed. This is an educational mapping, not legal advice.

TASK 5 – Scope and Rules of Engagement

The Rules of Engagement (RoE) is the operational boundary document. It must be signed by the system owner and assessment lead before any activity.

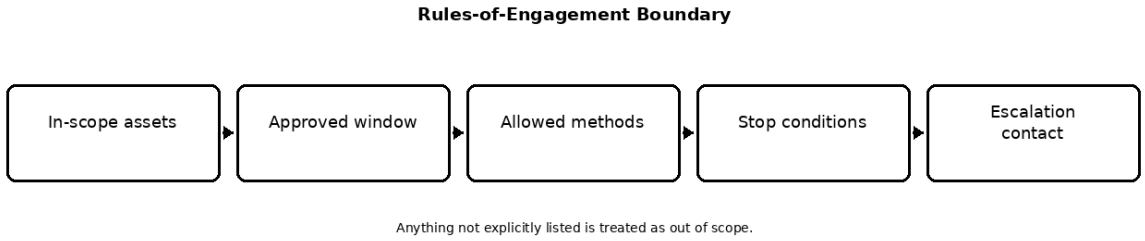


Figure 5. RoE boundaries define assets, time, methods, stop conditions and escalation.

RoE field	Example university rule
Engagement ID	UAS-2026-001
In-scope systems	Named student portal test instance, LMS staging server, approved lab network
Out-of-scope	Production databases, personal devices, third-party services not listed, physical access
Testing window	Approved date and time range stated in signed authorization
Permitted methods	Documentation review, configuration review, safe scanning of approved lab/staging assets
Prohibited methods	Denial-of-service, destructive payloads, persistence, data exfiltration and social engineering of real staff
Data handling	Use synthetic data; redact incidental personal information; encrypt evidence
Stop conditions	Service instability, unexpected sensitive data, scope uncertainty or owner request
Escalation	Assessment lead → system owner → security manager → legal/privacy contact

5.1 Authorization verification

6. Confirm requestor identity and authority to represent the system owner.
7. Verify the signed scope, asset list, dates, methods and emergency contacts.
8. Assign a unique engagement ID and store the approval in the central register.
9. Re-check authorization if assets, dates, methods or third parties change.

5.2 Pre-engagement checklist

Check	Yes / No	Evidence
Signed authorization received		Approval ID
In-scope and excluded assets listed		Approved inventory
Testing window and permitted methods agreed		RoE version
Data protection and retention rules approved		Privacy review
Emergency stop contact available		Contact record
Lab or staging environment verified		Configuration record

Any “No” means the engagement is not ready to start. An out-of-scope request is rejected or returned for formal amendment; verbal permission is not enough.

TASK 6 – Authorization and Responsible Disclosure Layer

Authorization and disclosure form a controlled lifecycle. The authorization layer prevents unapproved testing; coordinated disclosure ensures the owner receives enough information to reproduce and remediate a finding without exposing users.

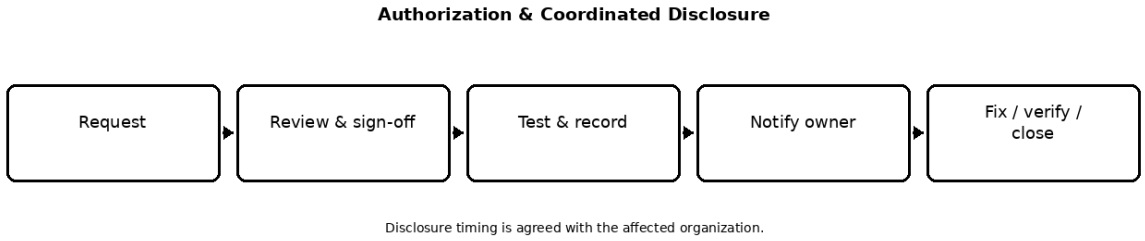


Figure 6. Approval, testing, notification, remediation and closure lifecycle.

6.1 Authorization workflow

10. Department submits a request with purpose, systems, dates and business owner.
11. Security governance checks scope, risk, privacy and legal requirements.
12. System owner and authorized institutional approver sign the RoE.
13. Engagement coordinator records the approval ID, version and permitted testers.
14. Testing begins only after all approval gates pass; changes require re-approval.

6.2 Responsible disclosure process

Stage	Action	Target timeline (proposed)
Report received	Acknowledge receipt and assign tracking ID	Within 2 business days
Triage	Validate safely and classify severity	Within 5 business days
Owner notification	Send minimal evidence to system owner	After validation
Remediation	Owner develops and deploys fix	30 days standard; urgent risks prioritized
Verification	Retest approved fix in lab/staging	Within 5 business days of fix
Closure	Record outcome and close report	After verification

6.3 Disclosure approach comparison

Approach	Description	Best use / limitation
Coordinated disclosure	Researcher informs owner privately and agrees remediation and publication timing	Default university approach; protects users while enabling a fix
Full disclosure	Details are made public without waiting for remediation	May create risk for users; use only after careful legal and safety review
Bug bounty	Reports are invited under published scope and reward rules	Useful at scale; needs clear eligibility, scope, triage and payment governance

A finding may proceed to public disclosure only after the owner has been notified, the agreed remediation window has been considered, sensitive data is removed and the security/legal leads approve release. Immediate public disclosure is not the default.

The finding report must link to the engagement ID and RoE version. If a finding is outside scope or exposes personal data, testing stops and the legal/privacy contact is notified.

TASK 7 – Isolated Ethical-Hacking Lab

The practical environment uses a host-only virtual network so the Kali Linux tester and target virtual machines communicate with each other without exposing the lab to the physical LAN or internet.

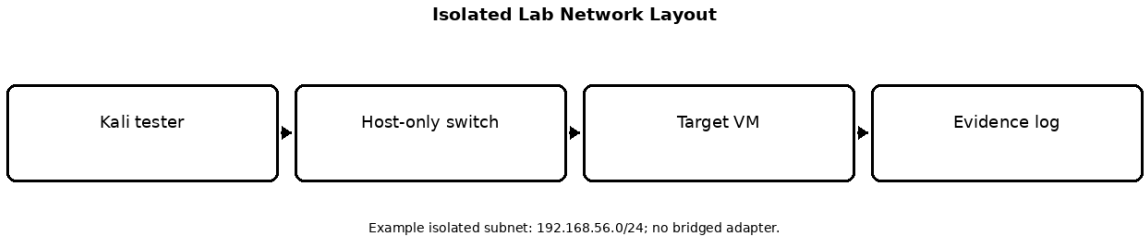


Figure 7. Isolated host-only lab. Example network: 192.168.56.0/24.

Component	Role	Example configuration
Kali Linux VM	Authorized tester workstation	192.168.56.10/24
Target VM	Intentionally vulnerable training machine	192.168.56.20/24
Host-only virtual switch	Private connectivity between VMs	192.168.56.0/24
Evidence folder	Stores configuration screenshots and test logs	Access restricted; encrypted backup

7.1 Verification operations

- Record VM names, operating-system versions, virtual network adapter mode, MAC addresses and assigned IP addresses.
- Verify the tester and target are on the same host-only subnet. In the lab, use ping to confirm basic connectivity where ICMP is enabled.
- Confirm the virtual machines do not have bridged adapters. Disable shared folders and clipboard unless explicitly needed.
- Save a snapshot before exercises and restore it after the lab session.

7.2 Host-only versus NAT

Feature	Host-only	NAT
VM-to-VM communication	Yes, within private virtual network	Usually yes, through virtual NAT network
Internet access	No by default	Outbound access commonly available
Isolation	Stronger separation from external networks	Less isolated because outbound traffic is possible
Use in this assignment	Preferred for contained target testing	Useful for updates, but separate from test network

The chosen model is host-only because the assignment emphasizes safe containment. If updates are required, use a separate controlled process and disconnect it before testing. Never connect a vulnerable target to a bridged campus network.

TASK 8 – Reusable Document Library

A reusable library standardizes evidence and prevents each department from inventing its own process. Four core documents are maintained with a common engagement ID.

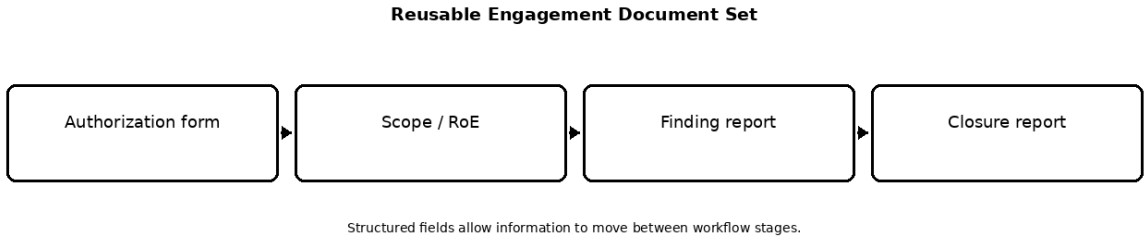


Figure 8. Four document templates and their connection to the engagement record.

Document	Required fields	Integration
1. Authorization form	Requestor, owner, purpose, assets, dates, methods, approver signatures, engagement ID	Creates the master engagement record
2. Scope / RoE	In-scope assets, exclusions, permitted methods, prohibited actions, stop conditions, escalation	Controls test execution
3. Finding report	Finding ID, engagement ID, asset, severity, evidence, impact, remediation, status	Feeds triage and disclosure register
4. Closure report	Retest result, residual risk, data disposal, approvals, closure date	Confirms remediation and closes engagement

8.1 Structured finding report example

Field	Example value
Finding ID	UAS-2026-001-F01
Engagement ID	UAS-2026-001
Asset	LMS staging server
Title	Example: insecure test configuration
Severity	Medium – pending owner validation
Evidence reference	EV-001 (redacted screenshot / log)
Impact	Potential exposure of non-production information
Recommendation	Apply approved configuration baseline
Owner / due date	LMS administrator / agreed date
Status	Open → In progress → Retest → Closed

8.2 Input validation tests

Test entry	Expected result	Reason
Valid approval with all signatures	Accept and assign engagement ID	Complete authority and scope
Missing system-owner signature	Reject / return for completion	Authorization incomplete
Finding references unknown engagement ID	Reject integration	No matching approved assessment
Report contains unredacted personal data	Quarantine and notify privacy contact	Sensitive evidence handling

The finding report exports structured fields to the disclosure register. This links technical evidence to authorization, owner notification, remediation and closure.

TASK 9 – Integrate, Test and Refine the Framework

The integrated walkthrough demonstrates how the modules work together for an authorized assessment of the LMS staging environment.

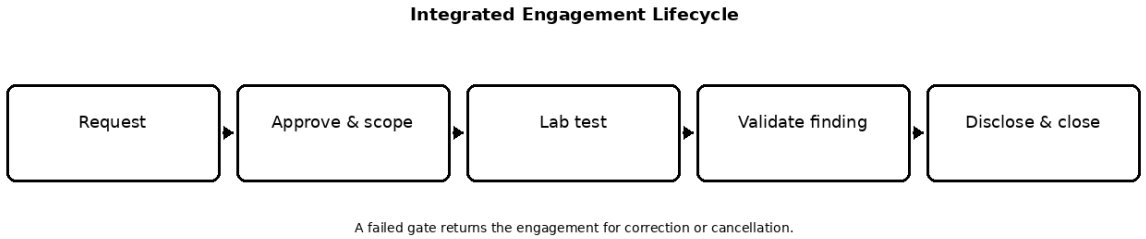


Figure 9. End-to-end assessment lifecycle with governance gates.

Step	Walkthrough action	Evidence / control
1. Request	IT department requests LMS staging assessment	Request form and business purpose
2. Approve	System owner and security approver sign	Authorization ID and RoE version
3. Scope	Confirm staging hostname and test window	Asset allowlist and exclusions
4. Prepare	Check privacy requirements and host-only lab	Privacy checklist and lab record
5. Assess	Perform approved non-destructive lab checks	Timestamped logs and evidence IDs
6. Report	Create finding with impact and remediation	Structured finding report
7. Disclose	Notify owner privately and agree due date	Disclosure tracking record
8. Verify / close	Retest fix and record closure	Retest evidence and closure report

9.1 Systematic test cases

Test case	Expected framework response
Missing authorization	Block start; return request for signature
Out-of-scope hostname	Stop activity; log and request scope amendment
Legal/privacy conflict	Pause and refer to legal/privacy officer
Delayed owner response	Escalate through agreed contacts; document timeline; do not publish automatically

9.2 Refinements from walkthrough

- Add an automated “authorization valid” check to the engagement register before a test plan can be marked ready.
- Add an out-of-scope stop condition to the tester checklist and lab procedure.
- Add a privacy review field to the finding report to prevent sensitive evidence from being circulated.
- Add escalation reminders for overdue remediation and owner acknowledgements.

The framework is considered integrated when every finding can be traced backward to a signed authorization and forward to an owner, remediation action and closure decision.

TASK 10 – Scalability and Governance Evaluation

Two programme sizes are modelled. The values below are illustrative planning scenarios; a real evaluation should replace them with measured results from a pilot.

Measure	Small programme	University-wide programme
Systems	20 systems	Approx. 200 systems (planning assumption)
Staff / assessors	50 staff; 2 internal testers	Multiple departments; 10 internal / external assessors
Approval path	Department owner + security lead	Department owner + central governance + legal/privacy + vendor review
Scope management	Single asset list	Central inventory with department-level scope records
Disclosure	One security contact	Central triage with named system owners

10.1 Process comparison

Process	Small programme estimate	Large programme estimate	Governance implication
Approval turnaround	2–3 business days	5–10 business days	Use standard forms and delegated approvers
Scope validation	1–2 review steps	3–5 review steps	Central asset inventory and owner mapping
Finding triage	1 security reviewer	Central triage plus system owner	Severity-based routing and SLA tracking

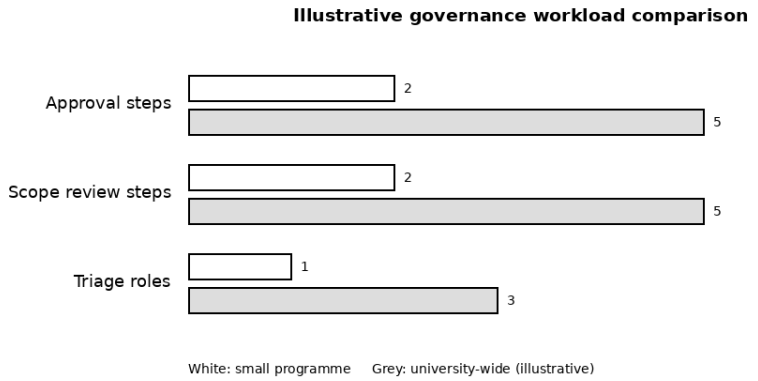


Figure 10. Example comparison of process steps and roles. Values are assumptions for design discussion, not measured outcomes.

10.2 Governance refinement

- Create a central engagement register with delegated department approvers.
- Use risk-based approval: low-risk lab work follows a shorter path; production-adjacent or personal-data work requires additional review.
- Introduce assessor onboarding, confidentiality agreements and access expiry for external testers.
- Track approval turnaround, percentage of assets with confirmed owners, scope exceptions and overdue findings each month.

The framework scales by standardizing documents and controls while allowing review depth to increase with system risk and programme size.

TASK 11 – Defend the Framework Under a Changed Requirement

The changed requirement introduces continuous assessments, third-party assessors, stricter data-protection rules and a shorter disclosure timeline. The framework must therefore become more automated and more explicit about identity, access expiry, evidence minimization and escalation.

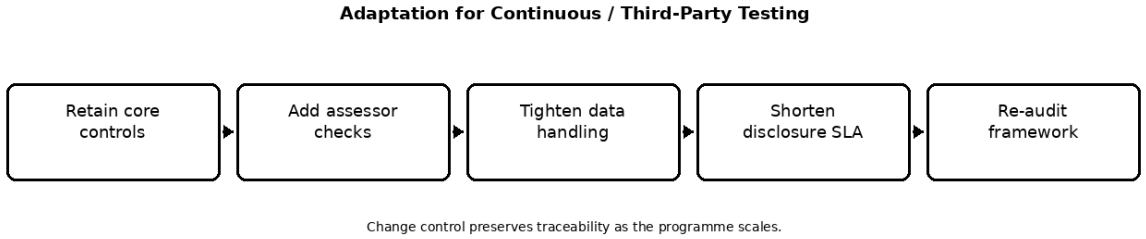


Figure 11. Revised framework for continuous and third-party assessments.

Component	Decision	Revision
Authorization	Retain + modify	Time-limited approval, named assessor identity and recurring renewal
Scope / RoE	Retain + strengthen	Version-controlled asset allowlist; rapid revocation and change approval
Legal / privacy	Strengthen	Privacy impact review, data minimization and retention schedule
Lab	Retain	Use isolated lab for repeatable tests; separate any production monitoring approval
Disclosure	Modify	Severity-based shorter acknowledgement and remediation targets
Document library	Retain + automate	Structured forms, mandatory fields and audit trail
Governance evaluation	Expand	Monthly metrics and external-assessor compliance checks

11.1 New component: third-party assessor control

15. Verify the assessor organization, named personnel, references and approved role.
16. Sign confidentiality and data-processing terms before access is granted.
17. Issue least-privilege accounts with expiry dates and multifactor authentication.
18. Restrict evidence access to the engagement team; encrypt storage and log downloads.
19. Revoke access at the end of the engagement and confirm evidence return or deletion.

11.2 Shortened disclosure targets

Severity	Proposed acknowledgement	Proposed owner action
Critical	Within 1 business day	Immediate containment review and frequent status updates
High	Within 2 business days	Remediation plan within 5 business days
Medium	Within 3 business days	Remediation plan within 10 business days
Low	Within 5 business days	Schedule into normal maintenance cycle

These are proposed internal service targets, not statutory deadlines. The university should approve them with system owners and legal/privacy staff.

11.3 Trade-offs and future improvements

- More approval gates improve control but may slow urgent assessments; risk-based delegation can reduce delay.
- Continuous monitoring improves visibility but increases log volume and privacy-management effort.
- External assessors add capacity but increase supplier, identity and evidence-handling risks.
- Future improvements include automated scope synchronization, evidence-retention enforcement, assessor recertification and periodic tabletop exercises.

Final Conclusion

The proposed ethical-hacking engagement framework combines authorization, scope, law, ethics, threat modelling, isolated testing, documentation, disclosure and governance measurement. It is suitable for the university because it prevents testing

from beginning without permission, keeps activity within defined boundaries, protects personal information and ensures findings are reported to accountable owners. Its modular design supports growth from a small programme to continuous university-wide assessments while retaining traceability and responsible disclosure.

Reference note: This assignment uses the legal instruments named in the question paper for educational mapping. Before a real engagement, the university should verify current statutory text, amendments, applicable data-protection rules and jurisdiction with qualified legal counsel.